Sociotechnical Security

CS 8803/4803

Professor Veronica Rivera

Lecture 15 – Intimate Partner Violence



Content warning: mentions of physical, sexual, emotional, and financial abuse caused by intimate partners and tech that enables the abuse

Last time

- Online hate and harassment
  - Taxonomies defining online hate and harassment
- Work on vulnerable populations
- Moderation
  - Limitations of moderation

Today

- First of two days on intimate partner violence (IPV)
- Introduce known-adversary threat model
- Prior work on understanding the problem of IPV from different angles

Two classes of attacks

- Previously: spyware adversaries
  - An adversary that installs or repurposes software to surveil a victim
- Today: UI-bound adversaries (known-adversary threat model)
  - An adversary that can authenticate into a device or service to interact with the system via the normal interface
  - Stronger: control the device
  - Weaker: only have the UI

How do we make progress?

Studying abusers & abuser resources



IPV spyware apps & defenses
[Chatterjee et al. Oakland 2018]
[Roundy et al. Oakland 2020]

reddit

Studying online infidelity forums
[Tseng et al. Security 2020]
[Bellini et al. CSCW 2020]

Designing interventions to support survivors



Clinical computer security
[Havron et al. Security 2019]
[Freed et al. CSCW 2019]
[Tseng et al. CHI 2021]

Security customer support
[Zou et al. Security 2021]

Slide credit: Tom Ristenpart

Understanding the problem

Usability looks at how easily, effectively, or efficiently a user can operate a system

Abusability looks at the possibility or design flaw that allows a system to be used maliciously to cause harm (aka abuse vectors from lecture 4)

Prior abusability work on:

- Financial apps
- Passkeys
- IoT devices
- Physical trackers
- Generative AI tools

Financial apps

Financial harm: the control of access, use, or maintenance of financial resources is a concern in IPV

Financial apps, including mobile banking and peer-to-peer payment apps could be used to cause financial harm

- Mobile banking
- Peer to peer payment

Financial apps

Research questions/goals

1. How resilient are financial technologies to UI-bound attacks?

2. What challenges do experts face mitigating these?

Presumed threat model

- Adversary has confidential information about the target (e.g., authentication info)
- Adversary can gain access to this through coercion/surveillance

Rosanna Bellini et al., The Digital Safety Risks of Financial Technologies for Intimate Partner Violence, USENIX Security 2023

Financial apps

Scoping review	Literature review for sociotechnical harms and adversarial tactics
UI step through	Identification of key application features, and manual stepthrough via simulated UI-bound adversarial attacks of 30 consumer-facing financial smartphone applications
Policy analysis	Analysis of ToS and AU policy documents on publicly-accessible P2PP applications
Abuse scenarios	Creation of three abuse scenarios to synthesize audit findings to engage non-stakeholders
Expert interviews	Conduct a series of semi-structured interviews with financial experts for evaluation and guidance

Financial apps

Harm category	Financial sociotechnical harms
Denial of service	Account and/or device control Account and/or device lockout Closure of account Denial of account creation (‘pre-hijacking’)
Harmful content	False abuse reporting Notification bombardment Private information exposure (‘doxing’) Profane/offensive content Spamming
Misrepresentation	False data and/or evidence Identity theft Impersonation (‘catfishing’)
Surveillance	Account and/or device monitoring Location tracking
Theft	Fraudulent payments Steal personal data

Simulated two threats in audit:

1. Those requiring physical proximity to a target’s device
2. Remote attacks through legitimate access

Audit

Physical proximity

- **Adding adversarial biometrics**
  - No P2PP apps alerted users or forced them to sign out
  - MB apps forced sign out but triggers varied and reason for logout was not communicated clearly with users.
- **Weak login**
- **Ongoing surveillance**
- **Theft of financial information:**
  - Several apps showed card PINs (4 MB, 3 P2PP).
  - 11 MBs and 3 P2PP apps let user freeze a card instantly with no extra check

Remote access

- **Fake account and impersonation**
  - No P2PP asked for gov't ID
- **Remote surveillance**
  - 5 of 17 P2PP apps showed transaction details publicly by default, to other users or to anyone with a profile link
- **Text-based harassment**
  - All 30 apps let abusive text and emoji go through in the payment memo field
  - Very few MB and P2PP apps have explicit anti-harassment mechanisms (e.g., blocking or reporting users)

Policy analysis

- Most P2PP terms make the account owner responsible for anyone else who uses their credentials.
- Many policies use unclear language that enables loopholes
- Few policies against harassment

Interviews

- Scenarios matched cases participants had seen
  - But they surfaced a gap in their understanding of how attacks are carried out
- P2PP can be helpful to survivors
- Challenges to UI-bound protections
  - Reluctance to change policies
  - Desire to repurpose but not redesign existing customer safety mechanisms
  - Absence of professional tools to detect UI-bound threats

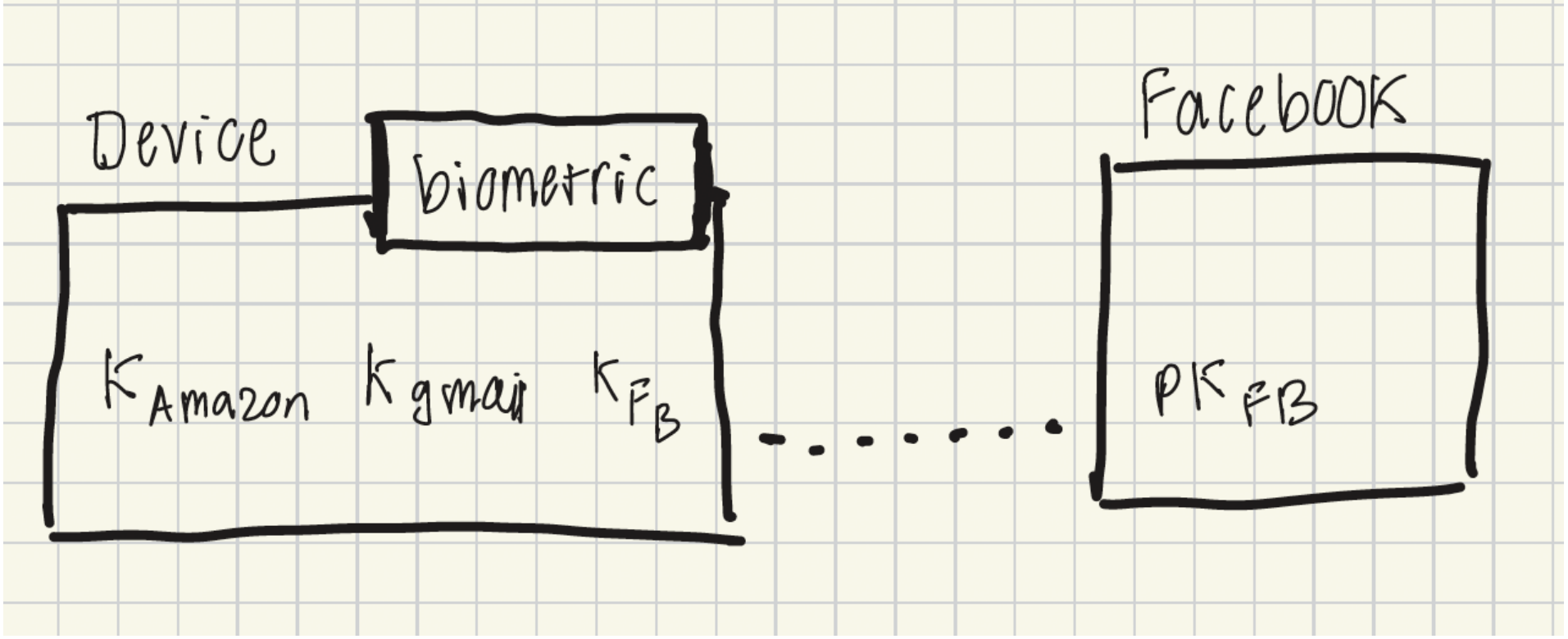
A framework for abusability analysis

#	Stage	Description	Output
1	*Identify threat models*	Determine a set of threat models, optionally aided by literature review	Set of threat models
2	*Assess functionality*	Open-ended exploration of system features	User pathways; screen captures; inventory of functionality
3	*Hypothesize abuse vectors*	Develop set of hypothetical abuse vectors by reviewing system functionality in light of threat models	List of hypothesized abuse vectors
4	*Design stepthrough protocols*	Develop set of stepthrough protocols to guide testing hypothesized abuse vectors, detection, and cleanup	List of step-by-step protocols to test abuse vectors
5	*Test abuse vectors*	Conduct stepthroughs to test abuse vectors	Evaluate viability of abuse vectors; stepthrough transcripts
6	*Summarize with scenarios*	Distill successful abuse vectors into short scenarios	Abuse scenarios

Alaa Daffalla et al., A Framework for Abusability Analysis: The Case of Passkeys in Interpersonal Threat Models, USENIX Security 2025

Recall: Passkeys

- Cryptographic credentials used for authentication
- Portable across devices



Passkeys – motivation and goal

Research questions/goals

1. To apply abusability analysis framework to recent passkey implementations

Presumed threat model

- Adversary that targets an individual
- Adversary is in the same social circles as the target
- Goals
  - Unauthorized access
  - Denial of service
  - Gaslighting
- Capabilities
  - Physical access to device & ability to unlock it
  - Ability to remotely login in victim's account from separate device

Passkeys – Tasks tested

Configure

Set up a passkey for primary authentication

Log in

Log into services with the passkey

Review

Review the information visible to users about the passkey

Transfer

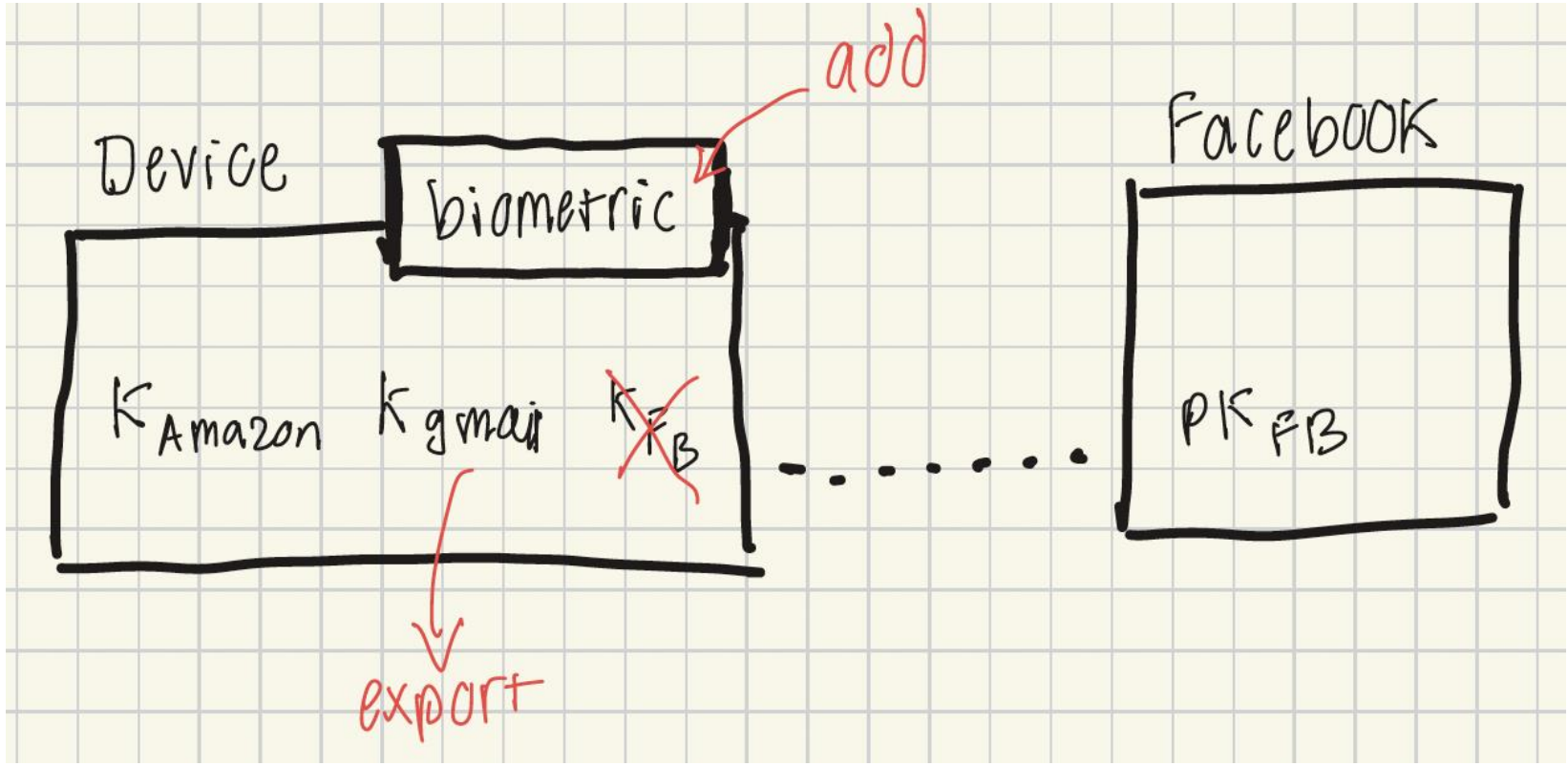
Export or transfer the passkey to a different device

Disable

Disable the passkey for service access

Some results

- Unauthorized access
- Passkey cloning
- Passkey deletion (denial of service)



Discussion